

ACTIVIDAD 01 - ANÁLISIS Y PLANIFICACIÓN DEL PENTEST

Caso: *Aurora Market*

Nombre completo: *Natacha Yael Lucas*

Fecha: *04 de septiembre de 2026*

Programa: *Hacker Women Council - Ethical Hacking*

1. OBJETIVO DEL PENTEST

1-Investigar el incidente reportado: Identificar y verificar posibles fallas en el control de acceso que permitan a un usuario acceder a información perteneciente a otras cuentas.

2-Evaluar la seguridad de la aplicación web: Auditar las funcionalidades críticas (autenticación, gestión de usuarios, catálogo, carrito y administración) para detectar vulnerabilidades que puedan ser aprovechadas por un atacante.

3-Proponer medidas de mejora: Documentar las vulnerabilidades encontradas y brindar recomendaciones técnicas y ejecutivas para reducir los riesgos, proteger la información de los clientes y fortalecer la seguridad de la plataforma.

2. ALCANCE

Sí se evaluará

- Aplicación web de **Aurora Market**.
- Módulos de autenticación, gestión de perfil, registro de usuarios e historial de pedidos.
- Panel de administración para empleados (gestión de productos, usuarios y pedidos).
- API / endpoints asociados a la plataforma web.

Fuera del alcance

- Redes sociales de Aurora Market.
- Equipos personales de empleados o clientes.

- Cuentas de correo electrónico de la empresa o empleados.
- Proveedores externos.
- Sistemas que no formen parte de la aplicación web autorizada.
- Información o sistemas de terceros.
- Cualquier acción que pueda interrumpir el funcionamiento de la plataforma o afectar información real de los clientes.
- Infraestructura de la base de datos y su configuración interna, salvo autorización expresa.

3. AUTORIZACIÓN Y CONDICIONES

Permisos requeridos

Antes de comenzar las pruebas se debe contar con:

- Autorización formal y por escrito de Aurora Market para realizar pruebas sobre la aplicación web.
- Definición clara del alcance de la evaluación.
- Contacto responsable de Aurora Market durante la evaluación.
- Permiso para registrar y documentar las vulnerabilidades encontradas.

Condiciones acordadas

- Las pruebas se realizarán únicamente sobre la aplicación web autorizada.
- No se atacarán redes sociales, equipos personales, correos, proveedores externos ni otros sistemas fuera del alcance.
- No se realizarán acciones que puedan interrumpir el servicio.
- Se evitará afectar o modificar información real de los clientes.
- Las pruebas se realizarán preferentemente durante horarios de menor actividad.
- Los resultados y evidencias obtenidos deberán manejarse de manera confidencial.

4. TIPO DE PENTEST

- **Tipo de pentest elegido: Gray Box**

Justificación de la elección: El pentest será de tipo Gray-Box porque el equipo cuenta con información parcial sobre el objetivo. Aurora Market informó que posee una aplicación web, una base de datos, mecanismos de autenticación y diferentes tipos de usuarios, pero no proporcionó detalles sobre la tecnología utilizada ni sobre cómo está construida la plataforma. Este enfoque permite evaluar la seguridad desde una situación intermedia: el equipo dispone de cierta información para orientar las pruebas, pero debe investigar otros aspectos durante el proceso. No corresponde a Black-Box porque ya se cuenta con información inicial de la plataforma, y tampoco a White-Box porque no se dispone de acceso al código fuente ni a las configuraciones internas.

5. PLANIFICACIÓN

Antes de comenzar las pruebas técnicas, el equipo debería realizar las siguientes tareas:

Objetivos

- Definir qué riesgos se quieren identificar.
- Determinar qué información y funcionalidades deben protegerse.
- Establecer los resultados esperados del pentest.

Alcance

- Identificar exactamente la aplicación web que será evaluada.
- Determinar qué funcionalidades, usuarios y componentes pueden ser analizados.
- Confirmar qué elementos quedan fuera del alcance.

Permisos y condiciones

- Verificar la autorización formal.
- Establecer las reglas de las pruebas.
- Definir horarios y contactos responsables.
- Determinar qué acciones están prohibidas para evitar interrupciones o daños.

Metodología a utilizar

Se propone utilizar **OWASP Web Security Testing Guide (WSTG)** como guía para organizar las pruebas de seguridad de la aplicación web.

Recopilación de información previa

- Identificar las funcionalidades disponibles.
- Analizar los mecanismos de autenticación.
- Identificar los diferentes tipos de usuarios.
- Reconocer los puntos de entrada de la aplicación.
- Revisar la información proporcionada por Aurora Market.

Recursos necesarios

- Equipo autorizado para realizar las pruebas.
- Herramientas de análisis de seguridad.
- Entorno de pruebas, cuando esté disponible.
- Registro de evidencias y resultados.
- Canal de comunicación con el responsable de Aurora Market.

Programación del pentest

Las pruebas deberán organizarse en etapas y realizarse preferentemente durante horarios de menor actividad, reduciendo así el riesgo de afectar las operaciones de la empresa.

6. FASES DEL PENTEST

1. Reconocimiento

Se recopilará información sobre la aplicación web dentro del alcance autorizado. Se identificarán sus funcionalidades, tipos de usuarios, mecanismos de autenticación, puntos de entrada y posibles superficies de ataque.

2. Análisis de vulnerabilidades

Se analizará la aplicación en busca de posibles vulnerabilidades de seguridad. Se prestará especial atención a la autenticación, autorización, gestión de sesiones, control de acceso, validación de entradas y protección de la información de los clientes. Los resultados deberán registrarse y clasificarse según su nivel de riesgo.

3. Explotación

Las vulnerabilidades identificadas podrán ser verificadas mediante pruebas controladas para determinar si son realmente explotables y conocer su impacto. La explotación deberá realizarse de manera segura, respetando las condiciones establecidas y evitando afectar el funcionamiento de la plataforma o los datos reales de los clientes.

4. Post-explotación

Si una vulnerabilidad es explotada de forma controlada, se analizará hasta dónde podría llegar un atacante y qué información o funcionalidades podría comprometer. No se buscará generar daños ni acceder innecesariamente a información real.

5. Informe

Finalmente se elaborará un informe con:

- Vulnerabilidades encontradas.
- Evidencias de cada hallazgo.
- Nivel de riesgo e impacto.
- Descripción de las posibles consecuencias.
- Recomendaciones para corregir o reducir los riesgos.

Esto permitirá que el equipo de desarrollo pueda revisar posteriormente los problemas encontrados, que es uno de los objetivos planteados por Aurora Market.

7. INVESTIGACIÓN

- **Metodología elegida:** *OWASP Web Security Testing Guide (WSTG)*

OWASP WSTG es una guía orientada a realizar pruebas de seguridad sobre aplicaciones y servicios web. Organiza las pruebas en diferentes áreas, permitiendo realizar una evaluación de seguridad de manera estructurada.

¿Por qué sería útil para Aurora Market?

OWASP WSTG es una guía ampliamente utilizada para la evaluación de aplicaciones web. Ofrece un marco estructurado con pruebas específicas para evaluar el control de acceso, la gestión de sesiones y la validación de entradas, permitiendo analizar de manera rigurosa y sistemática el incidente de fuga de información entre cuentas de Aurora Market.